

FG-VAPT

Comprehensive User Guide

v10.0 — FluentGrid Pvt Ltd

This guide covers all 30+ VAPT scanning tools, how to interpret results, understanding severity ratings, downloading reports, and recommended remediation steps. Intended for security analysts, QA engineers, and system administrators performing authorized vulnerability assessments.

Document	FG-VAPT Comprehensive User Guide
Version	10.0
Application	FG-VAPT — FluentGrid Vulnerability Assessment & Penetration Testing Suite
Audience	Security Analysts, QA Engineers, System Administrators
Classification	CONFIDENTIAL — Authorized Use Only
Generated	June 26, 2026

Table of Contents

1. Introduction to FG-VAPT	3
2. Getting Started	3
3. Understanding the Interface	4
4. Network & Port Scanning Tools (11 tools)	5
4.1 Port Scanner — Quick	5
4.2 Port Scanner — Full	5
4.3 Vulnerability Scan (NSE Scripts)	5
4.4 OS Detection	6
4.5 UDP Scan	6
4.6 Firewall Detection	6
4.7 Banner Grabbing	6
4.8 ARP Scan	7
4.9 SMB Enumeration	7
4.10 SNMP Enumeration	7
4.11 DNS Zone Transfer	7
5. Web Application Testing Tools (12 tools)	8
5.1 HTTP Header Audit	8
5.2 SSL/TLS Analysis	8
5.3 WAF Detection	8
5.4 Nikto Web Scanner	9
5.5 Directory Enumeration	9
5.6 Admin Panel Finder	9
5.7 CMS Detection	9
5.8 CORS Check	10
5.9 SQL Injection Test	10
5.10 XSS Scanner	10
5.11 HTTP Methods Audit	10
5.12 Subdomain Enumeration	11
6. Infrastructure Security Tools (8 tools)	11
7. Reconnaissance Tools (9 tools)	13
8. Advanced: Nuclei Scanner (6 tools)	14
9. Reports — Download & Consolidate	15
10. Understanding Severity & CVSS	16
11. Remediation Quick Reference	17
12. Legal & Ethics Disclaimer	18

1. INTRODUCTION TO FG-VAPT

What is FG-VAPT?

FG-VAPT (FluentGrid Vulnerability Assessment and Penetration Testing) is a comprehensive, web-based security testing platform developed by FluentGrid Pvt Ltd. Built on top of industry-standard tools such as Nmap, Nikto, SQLMap, Nuclei, and Gobuster, FG-VAPT provides a unified interface for performing 30+ security checks across network, web application, infrastructure, and reconnaissance categories.

Key Capabilities

- **Network Scanning:** Port discovery, OS detection, firewall analysis, SMB/SNMP enumeration
- **Web Application Testing:** SQL injection, XSS, header audit, SSL/TLS, WAF, directory brute-force
- **Infrastructure Security:** SSH/FTP/RDP checks, database exposure, Docker/K8s inspection
- **Reconnaissance:** WHOIS, DNS, IP geolocation, subdomain discovery, traceroute
- **Advanced Scanning:** Nuclei template engine for CVEs, misconfigurations, and critical findings
- **AI-Powered Analysis:** Attack chain analysis, risk scoring, 3-audience reports (Executive/Technical/Compliance)
- **Report Engine:** Individual scan reports + consolidated VAPT reports — downloadable as HTML

2. GETTING STARTED

Prerequisites

Component	Requirement	Notes
Python	3.8 or later	Download from python.org — add to PATH
Flask	<code>pip install flask</code>	Auto-installed by <code>install.bat</code>
Nmap	7.x (Windows installer)	https://nmap.org — required for port scans
gTTS	<code>pip install gtts</code>	Voice output feature
wafw00f	<code>pip install wafw00f</code>	WAF detection tool
Nuclei	Latest binary	https://github.com/projectdiscovery/nuclei — optional
Nikto (WSL)	<code>sudo apt install nikto</code>	Requires WSL2 + Kali Linux on Windows
Gobuster (WSL)	<code>sudo apt install gobuster</code>	Requires WSL2 + Kali Linux on Windows

The application saves scan results automatically to the **reports/** folder inside FG-VAPT. Reports persist between sessions.

3. UNDERSTANDING THE INTERFACE

Layout Overview

Area	Location	Purpose
Target Field	Top bar	Enter the IP address or domain to test (e.g. 192.168.1.1 or example.com)
Left Sidebar	Left panel	Tool categories: Network, Web, Infrastructure, Recon, Nuclei. Click any tool to run it.
Terminal Tab	Main area	Raw scan output — shows exactly what the tool returned
Ports Tab	Main area	Parsed open ports table — port number, service, state
Threats Tab	Main area	Parsed vulnerability findings with severity ratings
Risk Analysis Tab	Main area	Charts and attack chain analysis based on accumulated findings
Reports Button	Bottom-right (red)	Opens the Reports panel — download individual or consolidated reports
Report Button	Top-right toolbar	Existing quick download: HTML or TXT report of current session data
AI Chat	Right panel	Ask security questions, get remediation advice, query about any CVE or attack
Progress Bar	Below target	Live scan progress indicator with phase labels

Workflow — Step by Step

Step 1 — Enter Target — Type the IP or domain in the target field. Examples: 192.168.1.100, testphp.vulnweb.com, 10.0.0.0/24

Step 2 — Start with Recon — Run Ping, WHOIS, and DNS first to confirm the target is reachable and gather baseline info

Step 3 — Port Scan — Run Port Scanner (Quick) to discover open ports. Then run Full or Vuln scan for deeper analysis

Step 4 — Web Testing — If web ports (80, 443, 8080) are open, run HTTP Headers, SSL, WAF Detection, then Nikto

Step 5 — Infrastructure — Check SSH, FTP, RDP, and Database exposure on the discovered ports

Step 6 — Advanced — Run Nuclei Critical/High for automated CVE and misconfiguration checks

Step 7 — Reports — Click the red Reports button (bottom-right) → Download individual reports or the consolidated report

4. NETWORK & PORT SCANNING TOOLS

4.1 Port Scanner — Quick

Tool ID: `nmap_quick` Est. Duration: ~20 sec Risk if found: **MEDIUM**

Scans the top 100 most common ports using Nmap's fast scan. Reports open ports and detected services.

Command used:

```
nmap -Pn -T4 -F --open
```

What to look for in results:

- Open service names (ssh, http, ftp, rdp, smb)
- Port state: open / closed / filtered
- Service version hints if banner available

Examples & what they mean:

- Port 22 open → SSH service exposed
- Port 3306 open → MySQL database reachable
- Port 445 open → SMB enabled (Windows file sharing)

4.2 Port Scanner — Full

Tool ID: `nmap_full` Est. Duration: ~3 min Risk if found: **HIGH**

Full TCP scan with service version detection (-sV) and default NSE scripts (-sC). The most thorough port scan.

Command used:

```
nmap -Pn -T4 -sV -sC -A
```

What to look for in results:

- Service version numbers (e.g. OpenSSH 7.4)
- OS fingerprint estimate
- Default script results (e.g. HTTP title, SSL cert)
- Traceroute data

Examples & what they mean:

- Old software versions → known CVEs
- Unexpected open ports → shadow IT or misconfiguration
- OS version → guides further attack path selection

4.3 Vulnerability Scan

Tool ID: `nmap_vuln` Est. Duration: ~3 min Risk if found: **CRITICAL**

Runs Nmap's vulnerability NSE scripts against all open ports. Checks for known CVEs, default credentials, and dangerous service configurations.

Command used:

```
nmap -Pn --script vuln -sV -T4
```

What to look for in results:

- CVE references (e.g. CVE-2017-0144 EternalBlue)

- Vulnerability descriptions
- Exploit availability hints
- Affected service + version

Examples & what they mean:

- EternalBlue (MS17-010) → Remote code execution
- Heartbleed → SSL private key exposure
- Anonymous FTP login → unauthenticated file access

4.4 OS Detection

Tool ID: `nmap_os` Est. Duration: ~45 sec Risk if found: **LOW**

Uses Nmap's OS fingerprinting to identify the operating system, its version, and device type.

Command used:

```
nmap -Pn -O -sV
```

What to look for in results:

- OS name and version (e.g. Windows Server 2019, Ubuntu 20.04)
- Device type (router, server, workstation)
- Network distance (hops)

Examples & what they mean:

- End-of-life OS → no security patches available
- Unexpected OS → rogue device on network
- OS family guides selection of exploits

4.5 UDP Scan

Tool ID: `nmap_udp` Est. Duration: ~2 min Risk if found: **HIGH**

Scans the top 50 UDP ports. UDP services (DNS, SNMP, TFTP, NTP) are often overlooked but can be severely vulnerable.

Command used:

```
nmap -Pn -sU -T4 --top-ports 50
```

What to look for in results:

- Open UDP ports (53, 161, 69, 123 common)
- Service on each port
- Open|Filtered state is normal for UDP

Examples & what they mean:

- UDP 161 (SNMP) → often has default community strings 'public'
- UDP 53 (DNS) → zone transfer vulnerability
- UDP 69 (TFTP) → unauthenticated file access

4.6 Firewall Detection

Tool ID: `nmap_firewall` Est. Duration: ~25 sec Risk if found: **MEDIUM**

Uses TCP ACK scan and Nmap firewall bypass scripts to detect firewalls, packet filters, and IDS/IPS rules.

Command used:

```
nmap -Pn -sA -T4 + firewall-bypass script
```

What to look for in results:

- Filtered vs unfiltered ports
- Firewall rule behaviour
- Bypass possibility indicators

Examples & what they mean:

- Filtered ports → firewall blocking direct access (normal)
- Unfiltered on ACK scan → stateless firewall rules
- Bypass possible → firewall can be evaded

4.7 Banner Grabbing

Tool ID: `nmap_banner` Est. Duration: ~20 sec Risk if found: **MEDIUM**

Grabs service banners from open ports — software name and version returned by the service on connection.

Command used:

```
nmap -Pn --script banner -sV
```

What to look for in results:

- Service banner text (e.g. 'SSH-2.0-OpenSSH_7.4')
- FTP welcome messages
- HTTP server headers
- SMTP greetings

Examples & what they mean:

- Version info leakage → match against CVE databases
- Software end-of-life status
- Default banners → unchanged from out-of-box config

4.8 ARP Scan

Discovers all live hosts on the local network using ARP (Address Resolution Protocol). Only works on the local subnet — does not require the target to respond to ping.

What to look for: IP addresses + MAC addresses of all devices on the subnet. Unknown MAC vendors → unrecognised devices. Multiple IPs for one MAC → IP conflicts.

4.9 SMB Enumeration

Enumerates SMB (Server Message Block) shares, users, and OS information. Runs Nmap SMB scripts against port 445/139. Critical on Windows networks.

What to look for: Anonymous share access (no password), share names and permissions, SMB version (SMBv1 is critically dangerous — EternalBlue exploitable). NT_STATUS_ACCESS_DENIED = properly secured.

4.10 SNMP Enumeration

Queries SNMP (Simple Network Management Protocol) on UDP port 161 using default community strings 'public' and 'private'. SNMP leaks enormous amounts of system info if misconfigured.

What to look for: System description (OS, software), running processes, network interfaces, installed packages, user accounts. Any response = SNMP misconfigured and information leaking.

4.11 DNS Zone Transfer

Attempts AXFR (full zone transfer) against a DNS server. If misconfigured, the DNS server returns every hostname and IP in the domain — a complete map of the internal network.

What to look for: Lists of A, AAAA, MX, CNAME, NS records. Any successful transfer = HIGH severity finding. 'Transfer failed' or 'REFUSED' = properly secured.

5. WEB APPLICATION TESTING TOOLS

5.1 HTTP Header Audit

Tool ID: [web_headers](#)

Fetches and analyses all HTTP response headers. Security headers control browser behaviour and prevent common web attacks.

What to look for:

- Content-Security-Policy (CSP)
- X-Frame-Options
- Strict-Transport-Security (HSTS)
- X-Content-Type-Options
- Referrer-Policy
- Permissions-Policy

Common findings & severity:

Finding	Severity	Implication
Missing X-Frame-Options	HIGH	Clickjacking attacks possible
Missing HSTS	MEDIUM	SSL stripping attacks, HTTP downgrade
Missing CSP	HIGH	XSS attacks have no browser-level mitigation
Server: Apache/2.2.3	MEDIUM	Version disclosure → CVE lookup

5.2 SSL/TLS Analysis

Tool ID: [web_ssl](#)

Tests the SSL/TLS configuration of HTTPS services. Checks cipher suites, protocol versions, certificate validity, and common weaknesses.

What to look for:

- SSL/TLS version (TLS 1.0/1.1 deprecated)
- Certificate expiry and issuer
- Cipher suite strength
- Known vulnerabilities: POODLE, BEAST, Heartbleed, ROBOT

Common findings & severity:

Finding	Severity	Implication
TLS 1.0 enabled	HIGH	POODLE/BEAST attacks possible
Self-signed certificate	MEDIUM	No trusted CA — man-in-middle possible
Certificate expired	HIGH	Browsers block access; trust broken
Weak ciphers (RC4/DES/3DES)	HIGH	Ciphertext decryptable with modern compute

5.3 WAF Detection

Tool ID: [web_waf](#)

Uses wafw00f to fingerprint Web Application Firewalls. Knowing the WAF type helps plan the test and informs the customer about their protection layer.

What to look for:

- WAF name and vendor (Cloudflare, ModSecurity, Imperva, AWS WAF)
- WAF presence or absence
- WAF bypass indicators

Common findings & severity:

Finding	Severity	Implication
No WAF detected	HIGH	Attacks reach web app directly, unfiltered
Cloudflare	INFO	Known WAF — document for client; some bypasses known
ModSecurity (Apache)	INFO	Open-source WAF — rule quality varies

5.4 Nikto Web Scanner

Tool ID: [web_nikto](#)

Comprehensive web server scanner. Checks for thousands of dangerous files, outdated software, misconfigurations, and default content.

What to look for:

- + lines indicate findings (critical or interesting)
- Outdated server software
- Default files (phpinfo.php, test.php)
- Dangerous HTTP methods (PUT, DELETE)
- Backup files (.bak, .old)

Common findings & severity:

Finding	Severity	Implication
phpinfo() exposed	HIGH	Full server configuration leaked
PUT method enabled	CRITICAL	File upload to web server — code execution
Directory listing	MEDIUM	File structure exposed to attackers
Default credentials found	CRITICAL	Unauthenticated admin access

5.5 Directory Enumeration

Tool ID: [web_dirscan](#)

Brute-forces hidden directories and files using Gobuster (WSL) or custom HTTP probing. Discovers admin panels, backup files, API endpoints.

What to look for:

- HTTP 200 responses = found (accessible)
- HTTP 301/302 = redirect (accessible)
- HTTP 403 = found but forbidden (still a finding)
- Directory names: admin, backup, config, api, test

Common findings & severity:

Finding	Severity	Implication
/admin → 200	HIGH	Admin panel exposed
/.git → 200	CRITICAL	Source code repository leaked
/backup.zip → 200	CRITICAL	Full application backup downloadable
/.env → 200	CRITICAL	Database passwords, API keys in environment file

5.6 Admin Panel Finder

Tool ID: [web_admin](#)

Probes common admin panel paths. Checks for administration interfaces that should not be publicly accessible.

What to look for:

- Response codes for /admin, /administrator, /wp-admin, /phpmyadmin, /panel, /control
- Login page presence
- Default credential indicators

Common findings & severity:

Finding	Severity	Implication
/phpmyadmin accessible	CRITICAL	Database admin panel on public internet
/wp-admin found	HIGH	WordPress admin — brute-force target
/manager/html (Tomcat)	CRITICAL	App server manager — default creds often work

5.7 CMS Detection

Tool ID: [web_cms](#)

Identifies Content Management Systems (WordPress, Joomla, Drupal, Magento). Each CMS has known vulnerabilities and specific attack paths.

Look for: CMS name and version number. Outdated WordPress core or plugins = HIGH. E-commerce CMS (Magento/WooCommerce) = payment data at risk.

5.8 CORS Check

Tool ID: [web_cors](#)

Tests Cross-Origin Resource Sharing headers. Misconfigured CORS allows malicious websites to make authenticated API calls using a victim's session.

Look for: Access-Control-Allow-Origin: * with credentials = CRITICAL. Reflected Origin without validation = HIGH. Null origin accepted = HIGH.

5.9 SQL Injection Test

Tool ID: [web_sql](#)

Tests common SQL injection entry points using sqlmap-style payloads and manual detection patterns. Identifies databases vulnerable to data extraction.

Look for: Error messages containing SQL syntax. Time-based blind injection responses (slow responses to SLEEP() payloads). Any confirmed injection = CRITICAL.

5.10 XSS Scanner

Tool ID: [web_xss](#)

Tests for Cross-Site Scripting vulnerabilities. Injects payloads into URL parameters and common input fields.

Look for: JavaScript payloads reflected in responses. DOM manipulation indicators. Alert boxes in responses = confirmed XSS. Any confirmed XSS = HIGH to CRITICAL.

5.11 HTTP Methods Audit

Tool ID: [web_methods](#)

Tests which HTTP methods are accepted by the web server. Dangerous methods like PUT and DELETE should not be enabled.

PUT enabled = CRITICAL (file upload). DELETE enabled = HIGH (delete server files). TRACE enabled = LOW (cross-site tracing). OPTIONS revealing all methods = INFO.

5.12 Subdomain Enumeration

Tool ID: [web_subdomain](#)

Discovers subdomains of the target domain using DNS brute-force and certificate transparency lookups.

Look for: dev., staging., admin., vpn., mail., api. subdomains on public internet. Test each discovered subdomain separately.

6. INFRASTRUCTURE SECURITY TOOLS

6.1 SSH Audit

Tool ID: [infra_ssh](#)

Audits the SSH daemon: version, supported algorithms, deprecated key exchange methods, and banner information.

OpenSSH version → known CVEs. Weak key exchange (diffie-hellman-group1-sha1) = HIGH. Password authentication enabled (vs key-only) = MEDIUM. SSH version 1.x = CRITICAL (deprecated protocol).

6.2 FTP Check

Tool ID: [infra_ftp](#)

Tests FTP service on port 21. Checks for anonymous login, banner disclosure, and FTP bounce.

Anonymous FTP login = HIGH (unauthenticated file access). Plain-text FTP (not FTPS/SFTP) = MEDIUM (credentials transmitted in cleartext). Writable anonymous directory = CRITICAL.

6.3 RDP Check

Tool ID: [infra_rdp](#)

Checks Remote Desktop Protocol on port 3389. RDP is a frequent ransomware entry point when exposed to the internet.

RDP open on public IP = HIGH (brute-force, BlueKeep). NLA disabled = HIGH (pre-auth vulnerabilities). BlueKeep (CVE-2019-0708) indicator = CRITICAL. DejaBlue = CRITICAL.

6.4 Database Exposure

Tool ID: [infra_db](#)

Checks for exposed database ports: MySQL (3306), MSSQL (1433), PostgreSQL (5432), MongoDB (27017), Redis (6379), Elasticsearch (9200).

Any database port open on public internet = HIGH to CRITICAL. MongoDB/Redis with no auth = CRITICAL (all data readable). Elasticsearch port 9200 = CRITICAL (unauthenticated data access common).

6.5 Docker / Kubernetes Check

Tool ID: [infra_docker](#)

Checks for exposed Docker API (port 2375/2376) and Kubernetes API Server (6443, 8080, 10250).

Docker API on port 2375 (no TLS) = CRITICAL (full container control, host escape). K8s API without auth = CRITICAL. Kubelet port 10250 = CRITICAL (exec commands in pods).

6.6 CVE Scan

Tool ID: [infra_cve](#)

Runs intensive Nmap vulnerability scripts to check for specific CVEs across all open services.

Any confirmed CVE = immediate remediation required. CVE CVSS score 9.0+ = CRITICAL. Prioritise by CVSS score and whether exploit code is publicly available (check exploit-db.com).

6.7 WinRM Check

Tool ID: [infra_winrm](#)

Tests Windows Remote Management (WinRM) on ports 5985 (HTTP) and 5986 (HTTPS). WinRM allows remote PowerShell execution.

WinRM open with default credentials = CRITICAL. WinRM on public IP = HIGH. Used by attackers for lateral movement after initial compromise.

6.8 SNMP Audit

Tool ID: [infra_snmp](#)

Deep SNMP audit — checks default community strings, enumerates system info, processes, and interfaces.

Default 'public' community string = HIGH. Write community string 'private' = CRITICAL (can modify device config). SNMP v1/v2c = MEDIUM (cleartext, no auth). Only SNMPv3 with AuthPriv is secure.

7. RECONNAISSANCE TOOLS

7.1 WHOIS Lookup

Tool ID: [whois](#)

Retrieves domain registration info: registrar, creation date, expiry, nameservers, and registrant details.

Note the registrar and nameservers — useful for social engineering context. Check domain expiry date (expired = potential hijack). Historical ownership changes.

7.2 DNS Records

Tool ID: [dns](#)

Fetches all DNS record types: A (IPv4), AAAA (IPv6), MX (mail), NS (nameserver), TXT (SPF/DKIM), CNAME (aliases).

MX records reveal mail servers. TXT records show SPF/DKIM policy. Missing SPF = email spoofing possible. Multiple A records = load-balanced service.

7.3 IP Information

Tool ID: [ip_info](#)

Geolocates the IP address and retrieves ASN, ISP, country, city, and abuse contact information.

ASN reveals the hosting provider. Cloud provider IPs (AWS/Azure/GCP) = serverless/cloud-hosted app. Data centre country matters for data residency compliance.

7.4 Ping

Tool ID: [ping](#)

Basic ICMP connectivity check. Confirms the target is reachable and measures round-trip time.

No response = ICMP blocked by firewall (target may still be up). High RTT = distant server. Packet loss = unstable connectivity.

7.5 Traceroute

Tool ID: [traceroute](#)

Maps the network path to the target. Shows each router hop, IP, and latency.

Reveals network topology, CDN presence (Cloudflare/Akamai hops), geographic routing. Asterisks (*) = firewall blocking ICMP TTL-exceeded responses.

7.6 Local Network Scan

Tool ID: [network_scan](#)

ARP-based discovery of all live hosts on the local subnet. No target needed — scans your own network segment.

Baseline all devices on network. Unknown IPs/MAC addresses = unauthorised devices. Compare with DHCP lease list.

7.7 My IP

Tool ID: [my_ip](#)

Shows all network interface IP addresses of the machine running FG-VAPT.

Useful to confirm which network you are testing from. Note internal vs external IP. Confirm VPN tunnel IP if testing via VPN.

7.8 System Info

Tool ID: [system_info](#)

Displays system resource info: CPU, RAM, disk, OS version, hostname.

Baseline check for the FG-VAPT host. Verify sufficient resources for intensive scans (Nuclei, full port scan).

7.9 Weather

Tool ID: [weather](#)

Retrieves current weather data for Hyderabad, India.

Utility feature. No security testing value — included as ambient context in the dashboard.

8. ADVANCED: NUCLEI SCANNER

Nuclei is a fast, template-driven vulnerability scanner by ProjectDiscovery. It uses YAML templates to check for thousands of CVEs, misconfigurations, exposed panels, and default credentials. Nuclei must be installed separately from <https://github.com/projectdiscovery/nuclei/releases>.

Tool	Duration	What it checks	Best use
8.1 Nuclei Full Scan <code>nuclei_full</code>	~3 min	Runs all available Nuclei templates against the target. Most comprehensive check — covers CVEs, misconfigurations, exposed files, default credentials, and more.	The most thorough scan. Start here for unknown targets. Filter output by severity. Critical/High findings need immediate action.
8.2 Nuclei CVE Scan <code>nuclei_cve</code>	~3 min	Runs only CVE-tagged templates. Checks for specific published vulnerabilities with CVE numbers.	Each finding includes CVE ID, CVSS score, and remediation link. Cross-reference with NVD (nvd.nist.gov) for full details.
8.3 Nuclei Misconfiguration <code>nuclei_misconfig</code>	~2.5 min	Checks for security misconfigurations: open redirects, exposed Git repos, debug endpoints, insecure headers, CORS issues.	These findings are often overlooked but highly valuable to attackers. Debug endpoints and Git repos are CRITICAL.
8.4 Nuclei Tech Detection <code>nuclei_tech</code>	~1 min	Identifies technologies, frameworks, CMS, and software versions using response fingerprinting.	Use to build a technology map. Outdated versions → look up in CVE database. Framework fingerprint → guides targeted testing.
8.5 Nuclei Critical/High <code>nuclei_critical</code>	~3 min	Runs only Critical and High severity templates. Fastest path to the most dangerous findings.	Best scan to run when time is limited. Any finding here = immediate attention required.
8.6 Nuclei Network Scan <code>nuclei_network</code>	~2.5 min	Runs network-layer Nuclei templates: exposed services, default banners, port-specific checks.	Complements Nmap. Checks for service-level vulnerabilities not detected by port scanning alone.

9. REPORTS — DOWNLOAD & CONSOLIDATE

FG-VAPT stores every scan result automatically. You can download professional HTML reports at any time.

Individual Scan Report

Each completed scan generates a saved report with: the tool used, target, timestamp, open ports table, security findings with severity, and raw scan output.

How to download:

- Click the red **Reports** button (bottom-right corner of the application)
- The Reports panel opens showing all saved scan reports
- Click **HTML** button next to any scan to download that individual report
- The HTML file opens in any browser — share with client or save to findings folder

Consolidated VAPT Report

The consolidated report aggregates ALL scan results into one document. It includes: executive summary statistics, full list of all scans performed, deduplicated open ports across all scans, all security findings sorted by severity (Critical → High → Medium → Low), and target information.

How to download:

- Complete your desired scan set (run all relevant tools for your target)
- Click the red **Reports** button (bottom-right)
- Click **Download Consolidated Report** at the top of the panel
- Save the HTML file — suitable for client delivery or management review

Report Management

Action	How	Notes
View all reports	Reports panel → list	Shows tool, target, date, port count, finding count
Download individual	HTML button per row	Named: FG_VAPT____.html
Download consolidated	Top button in panel	Aggregates ALL saved scans into one report
Delete report	Trash icon per row	Removes from disk permanently
Report storage	D:\FG-VAPT\reports\	JSON files — persist between sessions
Quick report (existing)	Report button (top-right)	In-session HTML or TXT — no server persistence

10. UNDERSTANDING SEVERITY & CVSS

Severity	CVSS Range	What it means	Response time
CRITICAL	9.0 – 10.0	Unauthenticated remote code execution, full system compromise, data exposure. Exploits are typically publicly available.	Immediate — patch same day
HIGH	7.0 – 8.9	Significant impact: privilege escalation, authentication bypass, sensitive data leakage. May require user interaction or specific conditions.	24–72 hours
MEDIUM	4.0 – 6.9	Moderate impact: information disclosure, security header missing, weak cryptography, denial of service. Often requires authenticated access.	Within 2 weeks
LOW	0.1 – 3.9	Minor impact: informational leakage, best-practice violations, version disclosure. Low exploitability.	Next maintenance window
INFO	—	No direct vulnerability. Informational findings about technology stack, network topology, or configuration that aids attacker reconnaissance.	Review and document

CVSS Vector Components (Brief)

CVSS (Common Vulnerability Scoring System) v3.1 scores vulnerabilities across three metric groups:

Group	Metrics	Meaning
Base	AV, AC, PR, UI, S, C, I, A	Attack Vector, Complexity, Privileges Required, User Interaction, Scope, Confidentiality/Integrity/Availability impact
Temporal	E, RL, RC	Exploit code maturity, Remediation level, Report confidence — adjusts score over time
Environmental	MAV, MAC...	Your organisation's specific exposure and security controls — further adjusts the base score

11. REMEDIATION QUICK REFERENCE

Finding	Severity	Remediation
Open Ports Exposure	HIGH	Restrict with firewall rules. Allow only required source IPs/ports. Use network segmentation.
Missing Security Headers	MEDIUM	Add to web server config: X-Frame-Options: SAMEORIGIN, X-Content-Type-Options: nosniff, Strict-Transport-Security (HSTS), Content-Security-Policy.
TLS 1.0/1.1 Enabled	HIGH	Disable in web server config. Allow only TLS 1.2 and TLS 1.3. Update cipher suite list (remove RC4, 3DES, DES, MD5).
Default Credentials	CRITICAL	Change ALL default passwords immediately. Implement password policy. Enable MFA where possible.
Anonymous FTP/SMB	HIGH	Disable anonymous access. Require authentication. Restrict to internal network only.
SQL Injection	CRITICAL	Use parameterised queries / prepared statements. Input validation and output encoding. Web Application Firewall.
XSS Vulnerability	HIGH	Output encoding on all user input. Content-Security-Policy header. HTTPOnly and Secure cookie flags.
Directory Listing	MEDIUM	Disable in web server config (Options -Indexes in Apache, autoindex off in Nginx).
Exposed .git Repository	CRITICAL	Block access via web server (.htaccess or Nginx deny). Remove from public web root. Revoke all credentials in commit history.
SMBv1 Enabled	CRITICAL	Disable SMBv1 via PowerShell: Set-SmbServerConfiguration -EnableSMB1Protocol \$false. Patch MS17-010 immediately.
SNMP Default Community	HIGH	Change community strings from 'public'/'private'. Restrict SNMP to management VLAN. Upgrade to SNMPv3 with authPriv.
Docker API Exposed	CRITICAL	Bind Docker API to 127.0.0.1 only, or use TCP socket with TLS mutual authentication. Never expose port 2375 publicly.
Database Port Exposed	CRITICAL	Bind databases to 127.0.0.1 or private network interface only. Use firewall. Require authentication. Disable remote root login.
SSL Certificate Issues	MEDIUM	Renew expired certificates. Use certificates from trusted CAs only. Implement auto-renewal (Let's Encrypt + Certbot).
Outdated Software	HIGH	Apply vendor patches. Implement vulnerability management program. Track CVEs for all installed software versions.

12. LEGAL & ETHICS DISCLAIMER

IMPORTANT — Read Before Use

FG-VAPT is a professional security testing tool. Its use is governed by applicable laws and the following principles:

Authorisation Required: You MUST have explicit written permission from the system owner before running ANY scan. Scanning systems without permission is illegal under the Computer Misuse Act (UK), CFAA (US), IT Act 2000 (India), and equivalent legislation worldwide.

Scope Definition: Define the exact IP ranges, domains, and systems in scope BEFORE testing. Document this in a signed Rules of Engagement (RoE) document. Never test systems outside the agreed scope.

Data Handling: Scan results may contain sensitive system information. Store reports securely. Do not share findings with unauthorised persons. Destroy data after the engagement period ends.

Responsible Disclosure: If vulnerabilities are discovered, report them to the system owner through agreed channels. Do not exploit findings beyond what is necessary to demonstrate impact.

No Destructive Testing: FG-VAPT tools are configured for non-destructive assessment. Do not modify, delete, or exfiltrate data from target systems. Denial of service testing requires explicit approval.

Professional Conduct: Maintain confidentiality of all findings. The organisation's security posture is sensitive commercial information. Sign and honour any Non-Disclosure Agreement (NDA) provided.

By using FG-VAPT, you confirm that you are an authorised security professional conducting testing with the explicit permission of the target system owner, and that you accept full legal and professional responsibility for the use of this tool.
